Lab 5: Static Code Analysis

Parking Lot System | PES1UG24AM290 | Suhas | 27 October 2026

Objective and source

Improve code quality, security and style using Pylint, Bandit and Flake8, while preserving the assigned parking workflow.

https://github.com/SETAPESU26/L5_51_parking_lot_system

Source revision: f3fba6a9fd742604c8a906662eca8f9115ef976c

Measured results

Check	Before	After
Pylint 4.1.3	4.10/10; 36 diagnostics	10.00/10; 0 diagnostics
Bandit 1.9.4	5 findings: 2 High, 1 Medium, 2 Low	0 findings
Flake8 7.4.1	10 violations	0 violations
Regression tests	Not present in assigned source	16 tests passed

Method and evidence

The original script was run and scanned before edits. Fixes were grouped into three commits: Bandit security, Pylint quality and Flake8 formatting. Final scans use default checks with no suppression comments. Python 3.12.14 and isolated tool installations were used on Windows.

Raw before/after reports and command exit codes are included. The successful Flake8 report is empty because the tool produces no output when clean. The unchanged original is archived as a text snapshot.

Preserved workflow

The final demo parks P02, releases P01, reports P02 unavailable, calculates the surge fee as 45.0 and reports one vacant slot. Export remains a UTF-8 text mapping. Hashes now use SHA-256; PINs vary by design; only the configured status of the gate key is printed.

Security findings and fixes

Original-source line numbers are used throughout. Severity labels below are copied from Bandit's actual baseline output. All five findings are resolved in the final scan.

Issue / evidence	Original behaviour	Fix approach
Shell command injection Bandit B605 / High Lines 64	A filename was concatenated into os.system, allowing shell metacharacters to become commands.	Remove the shell call; print the export message directly.
Weak vehicle hash Bandit B324 / High Lines 53	MD5 is unsuitable for security-sensitive identifiers.	Use hashlib.sha256. A plate hash alone does not guarantee anonymity.
Arbitrary expression execution Bandit B307 / Medium; Pylint W0123 Lines 46-49	eval accepts executable Python rather than just a surge calculation.	Parse a restricted AST: numbers, base_rate, +, -, *, / and unary signs only. Bound expression length and nodes; reject non-finite or negative results.
Suppressed failures Bandit B110 / Low; Pylint W0702; Flake8 E722 Lines 27-33	A bare except silently discarded every error.	Catch KeyError only; return False for unknown slots and True on success.
Predictable ticket PIN Bandit B311 / Low Lines 56-57	The standard random generator is unsuitable for security tokens.	Use 1000 + secrets.randbelow(9000), retaining four-digit PINs.

Additional manual security fix

The gate credential embedded at original line 76 was printed at line 85. This did not appear as a separate Bandit finding in this run. The value now comes from PARKING_GATE_KEY and the demo prints only a Boolean. A subprocess regression test verifies non-disclosure.

Security boundaries

Allowed surge syntax is numbers, base_rate, parentheses, +, -, *, / and unary signs. Calls, attributes, indexing, powers and unknown names are rejected. Expressions are limited to 200 characters and 32 AST nodes; non-finite and negative results are rejected. A four-digit PIN is still small and not guaranteed unique; a plate hash is not an anonymization guarantee.

Quality and style findings

These fixes address the remaining Pylint and Flake8 diagnostics. Findings overlap across tools; they are grouped by underlying issue instead of counting the same defect twice.

Issue / original lines	Tool evidence	Fix approach
Shared mutable default Lines 15	Pylint W0102	Use None and create a fresh list when the caller does not supply logs.
Global scalar mutation Lines 12,16,22	Pylint W0603, C0103	Keep the running amount in COLLECTIONS['total']; remove global rebinding.
Resource handling Lines 60-63	Pylint R1732, W1514	Use a with block with encoding='utf-8'.
Redundant availability logic Lines 36-43	Pylint C0121, R1703, R1705; Flake8 E711	Return slot is not None and not slot['is_occupied'].
Unused and shadowed names Lines 4,37,47,67-71	Pylint W0611, W0612, W0621; Flake8 F401, F841	Use math for finite checks, remove dead locals, rename the parameter to slots, count values directly, and reference base_rate explicitly in the AST interpreter.
Missing documentation and naming Lines 1,15-75	Pylint C0114, C0116, C0103	Add module/function docstrings and snake_case function names; update all internal callers.
Formatting and string style Lines 7-9,23,88	Pylint C0301, C0304, C0209; Flake8 E501, W292	Wrap lines to 79 columns, use f-strings, and end the file with a newline.

Additional logic fixes

Importing the module no longer runs the demo. Invalid booking durations and blank plates are rejected before state changes. Functions now use snake_case, so external Python callers must use the new names; standalone execution remains the same. release_slot returns True or False explicitly.

Verification and reflection

All 16 regression tests passed. Checks cover parking and collections, rejected bookings, release and vacancy counts, arithmetic compatibility, malicious expressions, input limits, SHA-256, secure PIN boundaries, literal filenames, clean imports and gate-secret non-disclosure. Actual test output is in after/test_report.txt.

The supplied three-page handout does not list reflection questions, although the source README refers to four. These are four relevant lab reflection prompts, not quotations of missing questions.

1. What did each static analysis tool contribute?

Pylint exposed the shared mutable default, global rebinding, missing documentation and unnecessarily complex logic. Bandit identified five security findings, including shell execution and eval. Flake8 identified ten style or name-use violations. Their overlap helped confirm fixes, while their different scopes found different classes of defects.

2. Which issues were prioritized, and why?

The high-severity shell injection and MD5 findings and the medium-severity eval finding were addressed first. The shell call was unnecessary, so printing removed the risk entirely. A small arithmetic interpreter preserved base_rate * 1.50 while rejecting executable Python. Lower-severity exception handling and PIN generation issues were then fixed before the quality and formatting work.

3. What required care when applying the fixes?

Replacing eval with a simple numeric parser would have broken the original expression using base_rate. The replacement therefore supports only the arithmetic the program needs, with limits on input size and finite results. Renaming functions required updating all internal calls. Tests checked that collections, vacancy counts and the 45.0 surge-fee example still behaved correctly.

4. What are the benefits and limitations of static analysis?

Static analysis provides repeatable feedback without running every path and makes maintenance easier. A clean report does not prove correctness or security: manual inspection found the printed hardcoded gate credential and missing booking validation, neither of which appeared as separate findings here. Sixteen regression tests supplement the scans. In future work the three tools and tests can run on every change.

Commit evidence

08a49f6 - Bandit security fixes and baseline reports. 6408246 - Pylint quality and input validation. Final commit - Flake8 formatting, verified reports and deliverables. Use git log -3 --oneline in the parent repository for full history.